OSINT INTELLIGENCE REPORT

Target: Kortnit Technology
Objective: Identify publicly exposed information and assess how it could be leveraged by a threat actor.
Prepared by: Jordan Smith
Division: Kortnit Technology Advisory

Executive Summary: Threat Intelligence Profile – Kortnit Technology Worldwide, LLC

Corporate Overview & Strategic Posture

Kortnit Technology is a global leader in IT management, monitoring, and observability solutions. Headquartered in Austin, Texas, the company operates in 45 countries with a workforce of approximately 1,900 employees. As of February 2025, Kortnit Technology was acquired by **Turn/River Capital** for **$4.4 billion**, transitioning from a public entity to a private corporation.

The company's strategic direction for 2026 centers on **AI-driven observability**, tool consolidation, and addressing the "visibility gap" in hybrid cloud environments. Kortnit Technology has successfully pivoted to a subscription-first model, with recurring revenue accounting for **94%** of its **$796.9 million** FY2024 revenue.

Threat Landscape & Asset Inventory

Kortnit Technology represents a high-value target for both cyber-espionage and financially motivated actors due to its position in the global supply chain. Its software sits at the nexus of critical IT infrastructure for over 300,000 customers, including Fortune 500 companies and government agencies.

High-Value Data Assets:

- **Infrastructure Telemetry:** Real-time performance metrics, server logs, and application response data.
- **Sensitive Configurations:** Backups of network device configurations (routers, firewalls, switches) containing architectural blueprints.
- **Identity & Access Data:** Permissions and access rights via products like *Access Rights Manager*.

- **Intellectual Property:** Over 170 patents and proprietary R&D related to AIOps and automation.

Digital Footprint & Attack Surface

Kortnit Technology digital ecosystem is vast, designed for high-volume lead generation and community engagement.

- **SaaS & Software Delivery:** *Kortnit Technology Observability Platform* (SaaS and self-hosted) serves as the primary gateway for customer data.
- **THWACK Community:** A proprietary portal for IT professionals that, while a brand "moat," represents a significant platform for social engineering or credential harvesting.
- **Global Infrastructure:** Regional hubs in North America, EMEA, and APAC necessitate compliance with diverse data residency and privacy regulations.

Security Maturity & Resilience

Following the landmark 2020 supply-chain breach, Kortnit Technology has restructured its security philosophy under the **"Secure by Design"** initiative.

- **Hardened SDLC:** Implementation of a "Next-Generation Build System" designed to prevent unauthorized code injection.
- **Zero Trust Principles:** Increased focus on user access controls and data privacy governance.
- **AI Integration:** Heavy investment in AI and AIOps for proactive threat detection and reducing alert fatigue.

Key Risk Indicators (KRIs)

Risk Category	Status	Details
Supply Chain	**High**	Targeted due to deep integration into client environments.
M&A Transition	**Medium**	Integration risks following the Turn/River Capital acquisition (2025).
Model Shift	**Low**	Successful transition to subscription-based ARR ($729M).
Visibility	**Medium**	Organizations still struggle with "tool sprawl," increasing complexity.

OSINT Gathering

Google Dorking

Google Dorking & Search Reconnaissance

The initial search query has been updated to filter out the new primary domain to identify exposed third-party hosted assets.

- **Updated Dork:** `intext:"user name" intext:"orion core" -kortnittechnology.com`

- **Risk:** This identifies web consoles and login portals indexed by Google that are not part of the main corporate site but still belong to the organization's infrastructure.

This **Threat Intelligence Report** summarizes the findings from the recent reconnaissance exercise targeting Kortnit Technology infrastructure. It follows a professional structure intended for both technical response teams and security leadership.

Threat Intelligence Report: OSINT & Surface Reconnaissance

Report ID: TI-2026-03-27

Date: March 27, 2026

Target: Kortnit Technology (kortnittechnology.com)

Status: Initial Assessment

Confidence Level: High (based on indexed public data)

Summary (BLUF)

Passive reconnaissance via advanced search operators ("Google Dorking") has identified several vectors for potential information disclosure. While no active breach is confirmed, the indexing of sensitive file types and subdomains increases the risk of **credential harvesting**, **version-specific exploitation**, and **targeted phishing**.

Immediate action is recommended to audit robots.txt configurations and remove sensitive legacy documents from the public index.

Intelligence Analysis & Findings

A. Information Disclosure (Document Indexing)

The use of filetype:pdf combined with domain filtering revealed a large volume of indexed documentation.

- **Risk:** Publicly available PDFs often contain metadata (author names, software versions used to create the file) and internal naming conventions that assist in social engineering.
- **Key Finding:** Documentation related to **Serv-U (v15.5.4)** and **Microsoft-IIS/10.0** was identified, aligning with known infrastructure fingerprints.

B. Subdomain Enumeration

Broad domain queries (**site:kortnittechnology.com**) revealed a diverse attack surface, including staging environments and specialized portals (e.g., portal.kortnittechnology.com).

- **Risk:** Attackers often target "forgotten" subdomains that may lack the same rigorous security controls or MFA requirements as the primary site.

C. Vulnerability Context (Serv-U)

Current intelligence (as of Feb 2024–2026) indicates active targeting of **Kortnit Technology Serv-U** versions prior to **15.5.4** (CVE-2025-40538).

- **Observation:** The reconnaissance confirms the presence of these versions in the environment, making them a high-priority target for automated RCE (Remote Code Execution) scanners.

Adversary TTPs (Tactics, Techniques, & Procedures)

Based on the gathered data, an adversary would likely follow this kill-chain:

1. **Passive Recon:** Use Dorks to find login portals (inurl:login) or configuration files (filetype:env).
2. **Weaponization:** Match discovered server versions (IIS 10.0 / Serv-U) against public exploit databases.
3. **Initial Access:** Target the discovered login pages via credential stuffing using leaked passwords from previous breaches (e.g., historical "Kortnit Technology123" leaks).

Risk Assessment

Category	**Impact**	**Likelihood**	**Risk Level**
Information Leakage	Medium	High	**High**
Unauthorized Access	High	Medium	**High**

Category	Impact	Likelihood	Risk Level
Service Disruption	High	Low	**Medium**

Actionable Recommendations

Immediate (Tactical)

- **Index Purge:** Use Google Search Console to request the removal of sensitive or outdated PDF documents from the search index.
- **Robots.txt Update:** Audit and update robots.txt to explicitly disallow indexing of /admin, /login, /config, and /staging directories.
- **Version Masking:** Disable "Server" headers in IIS and Serv-U to prevent version-specific fingerprinting by passive scanners.

Strategic

- **Unified Observability:** Implement real-time monitoring to detect high-frequency "Dorking" behavior (excessive 404 errors or rapid directory traversal) originating from single IPs.
- **MFA Everywhere:** Ensure all discovered subdomains and portals require multi-factor authentication, regardless of their perceived sensitivity.

Indicators of Interest (IOI)

- **Serv-U Version:** 15.5.4
- **Web Server:** Microsoft-IIS/10.0
- **Top-Level Domains:** *.kortnittechnology.com

theHarvester

Threat Intelligence Report: Attack Surface Analysis

A comprehensive OSINT assessment was conducted to map the external infrastructure and identify potential entry points for an adversary. The investigation uncovered a massive digital footprint consisting of **979 unique hosts** and **109 active IP addresses**. Key findings include the exposure of sensitive development environments, direct download paths for administrative software, and specific employee details that could be leveraged for targeted social engineering.

Discovered Hosts & Infrastructure

- **Total Hosts Found:** 979
- **Active IP Addresses:** 109
- **Key Subdomains Identified:**
  - `vpn.kortnittechnology.com`
  - `bitbucket.kortnittechnology.com`
  - `api-staging.kortnittechnology.com`
  - `customerportal.kortnittechnology.com`
  - `thwack.kortnittechnology.com`

Exposed Emails & Identities

- `apacsales@kortnittechnology.com`
- `technicalsupportfeedback@kortnittechnology.com`
- `angelo.crizaldo@kortnittechnology.com`

Infrastructure & Asset Mapping

The organization maintains a high-density network architecture across multiple cloud and on-premise Autonomous Systems (ASNs), including Google (AS15169), Amazon (AS16509), and Microsoft (AS8075).

High-Value Subdomain Clusters

- **Authentication & Identity:** adfs.kortnittechnology.com, adfssso.kortnittechnology.com, and duo.kortnittechnology.com.
- **Development & Version Control:** bitbucket.kortnittechnology.com, artifactory.kortnittechnology.com, and argocd-produ.signpath.kortnittechnology.com.
- **Remote Management:** vpn.kortnittechnology.com, admin-takecontrol.kortnittechnology.com, and several regional VPN endpoints such as vpn-austin.kortnittechnology.com.

Exposed Sensitive Information

The reconnaissance identified specific URLs that disclose internal operational details and provide direct access to software installers:

- **Employee Information:** A documentation URL contains the email address of a specific employee (**angelo.crizaldo@kortnittechnology.com**) and internal campaign tracking parameters.
- **Software Distribution:** Publicly accessible paths were found for .zip installers of high-privilege tools, including DameWare v12.3.2.
- **Environment Exposure:** The presence of api-staging.Kortnittechnology.com, api-webdev.kortnittechnology.com, and dev-thwack.kortnittechnology.com suggests that pre-production environments are externally reachable.

Potential Adversary Attack Vectors

Attack Vector	Technical Finding	Real-World Threat
Supply Chain Attack	Exposure of artifactory and bitbucket.	An adversary gaining access to these repositories could inject malicious code into legitimate software updates.
Spear Phishing	Discovered emails like apacsales@kortnittechnology.com and individual employee names.	Targeted emails mimicking internal communications can be used for credential harvesting.
Credential Brute-Forcing	Direct login pages like hco.demo.kortnittechnology.com/Orion/Login.aspx.	Publicly exposed login portals for demo and production systems are primary targets for automated credential attacks.
Remote Access Exploitation	VPN endpoints and admin-takecontrol.kortnittechnology.com.	Vulnerabilities in remote access software can allow attackers to bypass the perimeter and gain internal network access.

Recommended Mitigations

1. **Harden Pre-Production Environments:** Restrict access to staging and dev subdomains using IP whitelisting or Client Certificates to prevent public discovery.
2. **Audit Software Distribution:** Ensure that direct download links for administrative tools (e.g., DameWare) are behind authenticated portals rather than public URLs.
3. **Credential Monitoring:** Implement strict Multi-Factor Authentication (MFA) across all identified login portals, particularly for demo environments that may have lower security standards.
4. **Information Sanitization:** Review public documentation and URLs to remove internal employee names and campaign tracking IDs that facilitate social engineering.

Shodan

An analysis of Shodan reconnaissance data reveals several publicly accessible Kortnit Technology demonstration environments hosted on Amazon Web Services (AWS) infrastructure. These assets encompass a variety of product lines, including **Security Event Manager (SEM)**, **Database Performance Analyzer (DPA)**, and **Observability** platforms. While identified as "demo" instances, the exposure of specific server versions, session management headers, and inconsistent security configurations presents a viable surface for adversary reconnaissance and targeted exploitation.

Shodan: Asset Fingerprinting

The following AWS-hosted demonstration environments were identified with their updated URLs and security headers:

Asset Name	Primary IP(s)	Updated URL / SSL	Server Header
WebClient	3.229.3.0	`ftp.kortnittechnology.com`	Serv-U/15.5.0.107
Observability	99.80.84.253	`*.oriondemos.kortnittechnology.com`	Microsoft-IIS/10.0
SEM	52.86.120.227	`oriondemo.kortnittechnology.de`	Not Disclosed

Infrastructure Overview

The identified assets are distributed across multiple AWS regions (US-East, US-West, EU-West, and AP-Southeast) and leverage diverse technology stacks.

Asset Name	Primary IP(s)	Server Header	Security Headers
WebClient (Serv-U)	3.229.3.0, 107.20.230.215	Serv-U/15.5.0.107	X-Frame, X-Content-Type, X-XSS
Kortnit Technology Observability	99.80.84.253, 54.66.193.219	Microsoft-IIS/10.0	HSTS, ASP.NET Session Cookies
Security Event Manager	52.86.120.227, 54.219.209.188	Not Disclosed	CSP, X-Frame-Options, X-Permitted-Policies
DPA Login Page	52.209.50.208	Not Disclosed	CSP (Limited)

Key Findings & Vulnerability Analysis

A. Serv-U WebClient Version Disclosure

Multiple instances are explicitly identifying as **Serv-U version 15.5.0.107**.

- **Risk:** Explicit versioning allows adversaries to quickly cross-reference known CVEs. While 15.5.x is relatively recent, any future zero-day or N-day vulnerability affecting this specific build can be instantly targeted across the footprint.
- **Observation:** The X-Frame-Options: same origin and X-Content-Type-Options: no sniff are correctly implemented here, providing some mitigation against clickjacking and MIME-sniffing.

B. Observability Platform Information Leakage

The Observability demo pages are running **Microsoft-IIS/10.0** and utilizing **ASP.NET** session management.

- **Risk:** The headers reveal Set-Cookie: ASP.NET_SessionId, which confirms the underlying framework. IIS 10.0 is the current standard, but revealing it assists in "fingerprinting" the OS (likely Windows Server 2016 or 2019/2022).
- **Observation:** These instances implement **HSTS** (max-age=31536000), which is a positive security posture for enforcing encrypted connections.

C. Inconsistent Content Security Policies (CSP)

There is significant variance in CSP implementation across the assets.

- **Security Event Manager:** Features a robust CSP (default-src 'self').
- **DPA Login:** Features a more permissive CSP that includes external domains like *.qualified.com and fonts.googleapis.com.
- **Risk:** Permissive CSPs or the lack thereof on certain subdomains could be leveraged for Cross-Site Scripting (XSS) if an adversary finds an injection point.

Adversary Threat Modeling

An adversary would likely follow this progression:

1. **Reconnaissance:** Use the wild-carded SSL certificates (*.kortnittechnology.com, *.oriondemos.Kortnittechnology.com) to discover further undocumented subdomains.
2. **Fingerprinting:** Target the **Serv-U** instances specifically due to the high-granularity version disclosure.
3. **Credential Harvesting:** Attempting brute-force or credential stuffing against the multiple "Login Page" endpoints identified (DPA, SEM, and Observability).
4. **Exploitation:** If a vulnerability is found in IIS 10.0 or Serv-U 15.5, these demo instances would serve as the initial "beachhead" to probe for internal connectivity to the primary Kortnit Technology corporate network.

Recommendations

- **Obfuscate Server Headers:** Remove or mask the Server header (e.g., Serv-U/15.5.0.107 and Microsoft-IIS/10.0) to increase the "cost of work" for an attacker.

- **Standardize Security Headers:** Ensure robust CSP and HSTS headers are applied consistently across all demo subdomains, not just selected ones.
- **Session Hardening:** Ensure the ASP.NET_SessionId cookie is flagged as HttpOnly and Secure to prevent client-side script access.
- **IP Whitelisting:** If these are strictly for "Demo" purposes, consider restricting access to known corporate or partner IP ranges rather than the global internet.

Maltego Visualisation

The reconnaissance phase identified a well-defined external perimeter consisting of active subdomains, specific network infrastructure (IPv4/IPv6), and functional email aliases. The most significant risks involve **Service-Specific Exploitation** (via the FTP subdomain) and **Advanced Social Engineering** (targeting the identified help desk and sales aliases).

Maltego: Infrastructure Visualization

The updated relationship map for the external perimeter is as follows:

- **Primary Node:** `www.kortnittechnology.com`
- **Infrastructure Links:**
  - `23.212.250.17` (IPv4)
  - `23.212.250.8` (IPv4)
  - `2600:1408:5400:2b::17dd:e3d0` (IPv6)
- **Service Endpoints:**
  - `mail.kortnittechnology.com`
  - `ftp.kortnittechnology.com`
  - `blog.kortnittechnology.com`

External Attack Surface Analysis

1.1 Infrastructure & DNS Assets

The following assets were mapped through DNS expansion and WHOIS transforms:

Asset Type	Identifier(s)	Risk Level
Primary Domain	kortnittechnology.com	Low
High-Value Subdomain	ftp.kortnittechnology.com	**High**
Informational Subdomains	blog.kortnittechnology.com, email.kortnittechnology.com	Medium
Network Endpoints	23.212.250.17, 23.212.250.8	Medium
IPv6 Range	2600:1408:5400:2b::17dd:e3d0/e3e5	Medium

Note: The presence of a dedicated ftp subdomain suggests a potential vector for data exfiltration or software supply chain tampering if the underlying service is unpatched or permits weak authentication.

1.2 Identity & Communication Vectors

A harvest of public-facing email addresses revealed specific departmental targets:

- **Administrative:** abusereport@key-systems.net (Registrar-level contact)
- **Operational:** webhelpdeskaccount@... (Internal support/system alias)
- **Commercial:** sales@kortnittechnology.com

Threat Actor Perspective (Adversary Simulation)

Based on the gathered intelligence, an adversary is likely to follow this kill-chain progression:

1. **Reconnaissance (Completed):** Mapping the 23.212.x.x range and identifying the FTP endpoint.
2. **Weaponization:** Crafting a phishing payload disguised as an "Internal Support Ticket" using the webhelpdeskaccount alias to gain trust.
3. **Delivery:** Sending the payload to employees likely to interact with the Sales or Help Desk departments.
4. **Exploitation:** Attempting to brute-force the ftp.kortnittechnology.com server using common administrative credentials or exploiting known vulnerabilities in the service version.

Sigma Detection Strategy

To mitigate the risks identified, the following monitoring logic should be implemented in the SIEM:

Log Source: Web/Proxy/FTP Logs

YAML

title: Unauthorized FTP Access Attempts

YAML

```yaml
title: Unauthorized FTP Access Attempts
description: Detects unusual login patterns on the FTP subdomain.
detection:
  selection:
    Target Hostname: 'ftp.kortnittechnology.com'
  condition: selection and count() > 10 within 1m
level: high
```

Log Source: Email Gateway Logs

YAML

title: Help Desk Account Spoofing

YAML

```yaml
title: Help Desk Account Spoofing
description: Detects incoming external emails using internal
  alias names in the 'Display Name' field.
log source:
    product: m365 / iron port
detection:
    selection:
        Header From|contains: 'web helpdesk'
        Source: 'External'
    condition: selection
level: critical
```

Strategic Recommendations

- **Decommission Legacy Services:** If the ftp subdomain is not required for current operations, it should be disabled or moved behind a VPN.
- **Implement DMARC/SPF/DKIM:** Ensure strict enforcement to prevent attackers from successfully spoofing the identified email aliases.
- **IP Whitelisting:** Restrict access to the 23.212.x.x endpoints to known corporate ranges or authorized third-party integrators.

Threat Actor Analysis: Kortnit Technology

This section evaluates the threat actor groups most relevant to Kortnit Technology based on its sector, historical compromise, and current digital exposure.

1.1 Threat Actor 1 — APT29 (Cozy Bear)

- **Origin:** Russian State-Sponsored (SVR)
- **Motivation:** Strategic Cyber Espionage
- **Primary Targets:** Government, Technology, Supply Chain Providers

Relevance to Kortnit Technology:

APT29 is the primary adversary associated with the historic 2020 supply chain attack. They target Kortnit Technology specifically to gain "upstream" access to thousands of high-value downstream enterprise and government clients.

Key TTPs (MITRE ATT&CK):

| Technique | ID | Description |

| :--- | :--- | :--- |

| **Spear Phishing** | T1566 | Highly targeted, socially engineered emails. |

| **Supply Chain Compromise** | T1195 | Manipulating trusted software updates. |

| **Valid Accounts** | T1078 | Utilizing legitimate credentials to remain stealthy. |

1.2 Threat Actor 2 — FIN7

- **Origin:** Financially Motivated Cybercriminal Group
- **Motivation:** Direct Financial Gain (Ransomware/Theft)
- **Primary Targets:** Retail, Hospitality, Tech Infrastructure

Relevance to Kortnit Technology:

While not state-sponsored, FIN7 targets high-value tech infrastructure like Kortnit Technology to deploy ransomware or loaders (e.g., Carbanak) for large-scale extortion.

1.3 Risk Connection Analysis

This section demonstrates how discovered OSINT data points translate into viable attack vectors.

Scenario: Spear Phishing via Email Enumeration

- **Exposure:** Predictable firstname.lastname@kortnittechnology.com formats + indexed login portals.
- **Exploitation:** Attackers use tools like *theHarvester* to build a target list and deploy cloned authentication pages.
- **Risk Level: CRITICAL**

Scenario: Exploitation via Software Version Disclosure

- **Exposure:** Service banners (e.g., Serv-U/15.5.4) revealed via Shodan.
- **Exploitation:** Matching exposed versions against known CVEs to launch public or 0-day exploits for initial access.
- **Risk Level: CRITICAL**

Note: The real risk is not any single exposure, but the **attack chain** formed when a sophisticated actor like APT29 combines them.

1.4 Strategic Recommendations

Prioritized actions to mitigate the identified risks.

Priority 1: Immediate Remediation (0–7 Days)

1. **Strengthen Authentication:** Enforce Phishing-Resistant MFA (Hardware tokens/FIDO2) across all portals.
2. **Obfuscate Infrastructure:** Disable or mask server banners and version disclosures in production environments.

Priority 2: High Risk Reduction (30–60 Days)

1. **Attack Surface Management:** Decommission "zombie" subdomains and stale APIs discovered during reconnaissance.
2. **Document Sanitization:** Review and remove internal architecture diagrams or configuration details from indexed PDFs.

1.5 Prioritized Action Plan

Priority	Action	Timeline
Critical	Enforce MFA & Secure Portals	Immediate
Critical	Remove Version Disclosures	Immediate
High	Audit Subdomains & APIs	30 Days
Medium	Sanitize Public Documentation	60 Days

1.6 Ethical Considerations

This assessment was conducted under strict **Rules of Engagement (RoE)**:

- **Passive Only:** No interaction with Kortnit Technology systems or active probing occurred.
- **Public Data:** Only publicly available information (OSINT) was utilized.
- **Responsible Disclosure:** No sensitive credentials or documents were downloaded or retained.